Cymbal Retail

Final Incident Report

Data Breach in the Google Cloud Environment

Organization:	Cymbal Retail
Incident:	Unauthorized access to VM cc-app-01 and exposure of card data in BigQuery
Prepared by:	Paul Chola Bwembya Mumbi
Role:	Associate Cloud Security Analyst and IT Support, FRA Intern
Date:	12 October 2026
Status:	Final
Classification:	Public - Project

Prepared for the lessons learned meeting

Contents

Executive summary 3
Detection and findings 4
Response and remediation 6
Containment and eradication measures 7
Recovery measures 8
Recommendations 11
Remaining work 12

Table of Figures

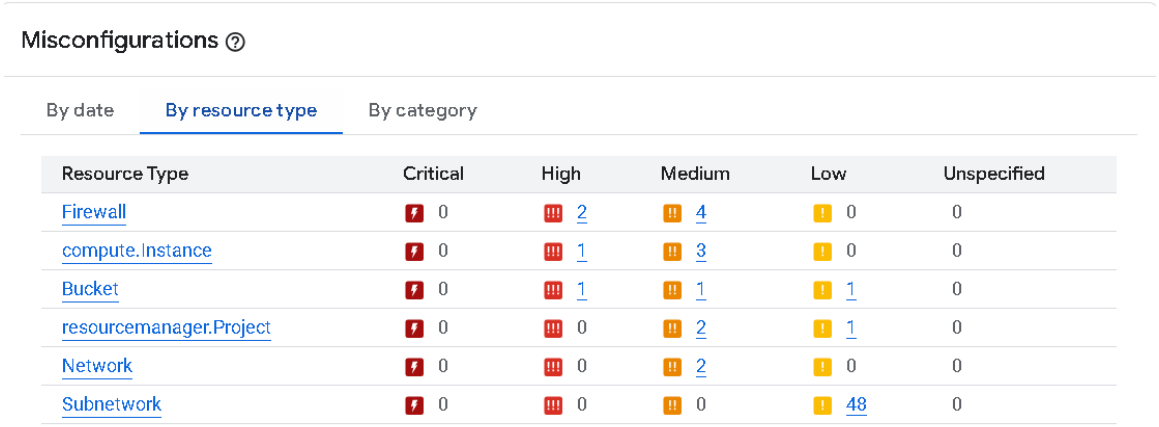
Figure 1. SCC misconfigurations by resource type. 4
Figure 2. SCC risk overview, with no critical or high threats in the last week. 4
Figure 3. PCI DSS 3.2.1 compliance dropping below 100% in early October 2026. 5
Figure 4. Control 10.1: VPC Flow Logs off on 24 subnets, firewall logging off on 4 rules, Cloud Audit Logging not set up properly. 5
Figure 5. Controls 10.1, 10.2 and 1.2.1, including the open RDP (3389) and SSH (22) rules. 6
Figure 6. cc-app-01 stopped. 7
Figure 7. Boot disk: cc-app01-snapshot, 10 GB balanced persistent disk. 8
Figure 8. cc-app-02 machine configuration (e2-medium, us-east4). 9
Figure 9. Networking: HTTP and HTTPS off, IP forwarding off, cc network tag. 9
Figure 10. Default subnet, with the external IPv4 address set to None. 10
Figure 11. Service account selection. 10
Figure 12. cc-app-02 running, cc-app-01 stopped. 11

Executive summary

Cymbal Retail had a data breach in its Google Cloud environment. Credit card numbers, user names and locations were exposed for a large number of customers. Our team noticed unusual activity, confirmed a serious compromise, and started going through the logs to see how far it went. We have not been able to tell who did it, and the forensic work to pin down exactly when it happened is still going. The attacker got in through the VM cc-app-01. It had a public IP address, and the firewall allowed SSH (port 22) and RDP (port 3389) from any address. They guessed weak credentials with a brute-force attack, logged in, and put malware on the machine so they could stay there. While on the VM, they found a service account key that someone had created by hand. The VM was also running as the default service account, which had full access to every Cloud API. With those credentials, the attacker reached Big Query, where the card data was stored without encryption. They copied it out through a Cloud Storage bucket that was open to the public internet. Security Command Center (SCC) flagged the problems, and our PCI DSS 3.2.1 compliance score dropped below 100% in early October 2026. The affected resources were cc-app-01, its service account and key, BigQuery, the public bucket and the firewall rules. To contain it, we shut down and deleted cc-app-01 then fixed the firewall rules and locked down the bucket. We rebuilt the application as cc-app-02 from a trusted snapshot, with a private IP, secure boot and its own service account. SCC now shows no critical or high threats from the last week.

Still open: who did it, exactly when, and a few logging gaps and smaller findings.

Detection and findings



Misconfigurations

By date | By resource type | By category

Resource Type	Critical	High	Medium	Low	Unspecified
Firewall	0	2	4	0	0
compute.Instance	0	1	3	0	0
Bucket	0	1	1	1	0
resourcemanager.Project	0	0	2	1	0
Network	0	0	2	0	0
Subnetwork	0	0	0	48	0

Figure 1. SCC misconfigurations by resource type.

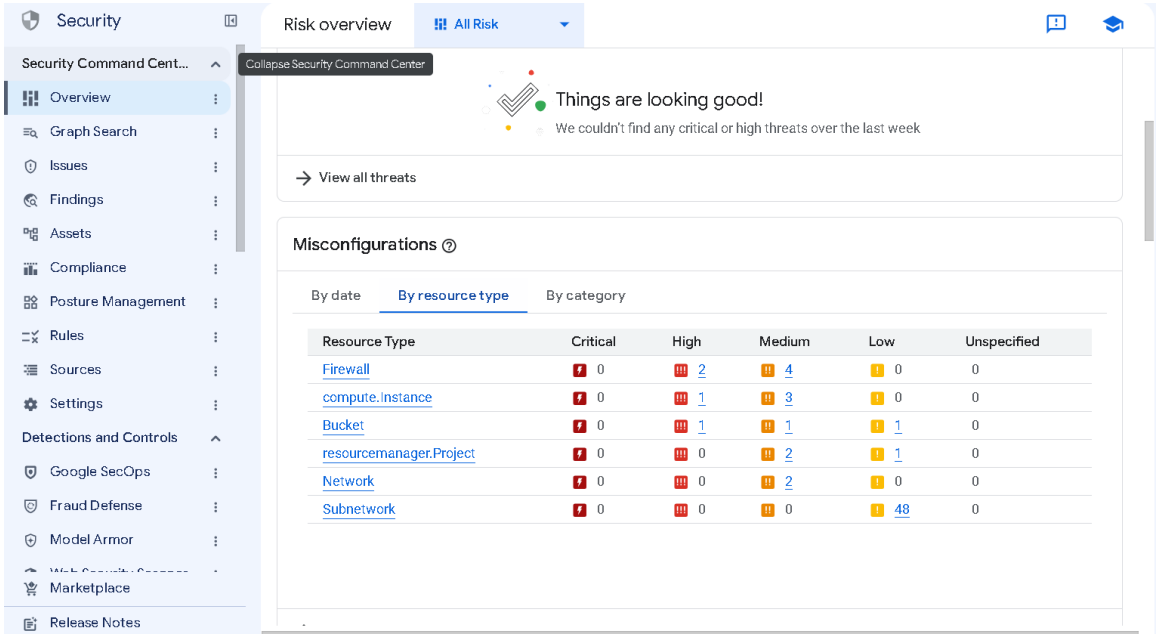


Figure 2. SCC risk overview, with no critical or high threats in the last week.

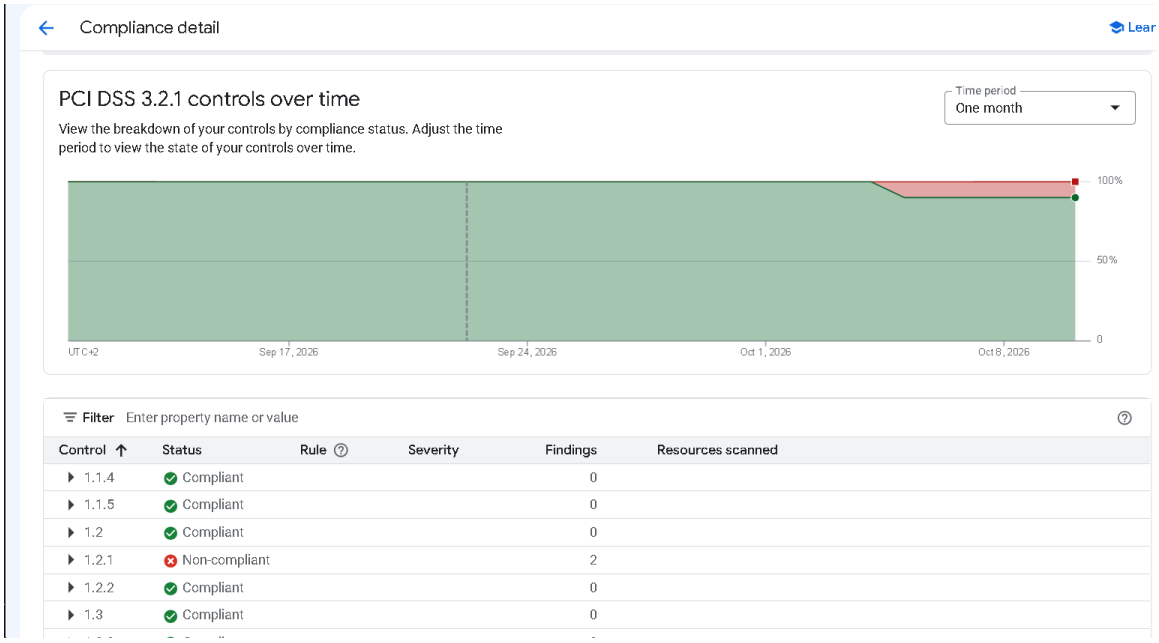


Figure 3. PCI DSS 3.2.1 compliance dropping below 100% in early October 2026.

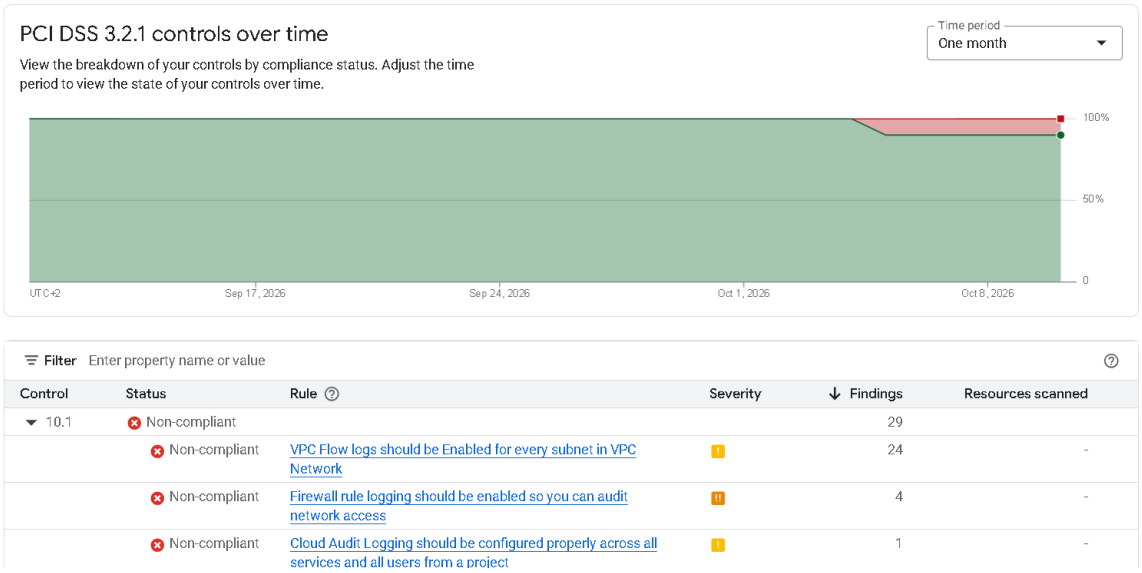
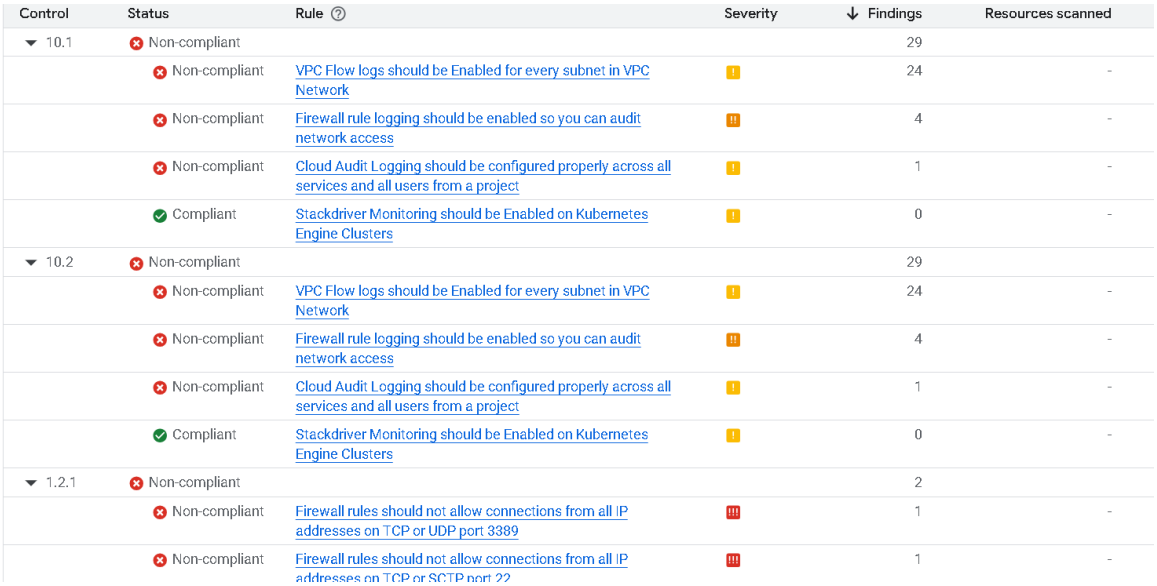


Figure 4. Control 10.1: VPC Flow Logs off on 24 subnets, firewall logging off on 4 rules, Cloud Audit Logging not set up properly.



Control	Status	Rule	Severity	Findings	Resources scanned
10.1	Non-compliant			29	
	Non-compliant	VPC Flow logs should be Enabled for every subnet in VPC Network		24	-
	Non-compliant	Firewall rule logging should be enabled so you can audit network access		4	-
	Non-compliant	Cloud Audit Logging should be configured properly across all services and all users from a project		1	-
	Compliant	Stackdriver Monitoring should be Enabled on Kubernetes Engine Clusters		0	-
10.2	Non-compliant			29	
	Non-compliant	VPC Flow logs should be Enabled for every subnet in VPC Network		24	-
	Non-compliant	Firewall rule logging should be enabled so you can audit network access		4	-
	Non-compliant	Cloud Audit Logging should be configured properly across all services and all users from a project		1	-
	Compliant	Stackdriver Monitoring should be Enabled on Kubernetes Engine Clusters		0	-
1.2.1	Non-compliant			2	
	Non-compliant	Firewall rules should not allow connections from all IP addresses on TCP or UDP port 3389		1	-
	Non-compliant	Firewall rules should not allow connections from all IP addresses on TCP or SCTP port 22		1	-

Figure 5. Controls 10.1, 10.2 and 1.2.1, including the open RDP (3389) and SSH (22) rules.

Response and remediation

The table lists each vulnerability that contributed to the breach and what we did about it.

Resource	Severity	Vulnerability	Remediation
Storage bucket	High	Public bucket ACL	Removed public access.
Storage bucket	Medium	Bucket policy only disabled	Switched to uniform bucket-level access.
Storage bucket	Low	Bucket logging disabled	Still open (see Remaining work).
VM cc-app-01	High	Public IP address	New VM cc-app-02 has a private IP only.
VM cc-app-01	Medium	Secure boot disabled	Secure boot turned on for cc-app-02.
VM cc-app-01	Medium	Default service account used	cc-app-02 uses its own service account.
VM cc-app-01	Medium	Full access to all Cloud APIs	Default account is no longer attached.
VM cc-app-01	Low	Malware: bad domain	Infected VM deleted; cc-app-02 built from a trusted snapshot.
Firewall	High	Open SSH port (22)	SSH limited to 35.235.240.0/20 with the limit-ports rule.
Firewall	High	Open RDP port (3389)	Default RDP rule deleted.
Firewall	Medium	Firewall rule logging disabled	Logging turned on.

Containment and eradication measures

1. We shut down the infected VM, cc-app-01, so the attacker lost their connection, and then deleted it.
2. We used the Compliance page in SCC to see which PCI DSS controls were failing (1.2.1, 10.1 and 10.2).
3. We created a new firewall rule, limit-ports, that only allows SSH (TCP 22) from 35.235.240.0/20, the range Google's Identity-Aware Proxy uses. It only applies to instances with the cc network tag.
4. We deleted default-allow-icmp, default-allow-rdp and default-allow-ssh, since they let anyone connect.
5. We turned on logging for limit-ports and default-allow-internal so there is a record of the traffic they allow.
6. We removed public access from the storage bucket the attacker used to get the data out.
7. We switched the bucket from fine-grained ACLs to uniform bucket-level access, so permissions are only set at the bucket level.
8. We checked SCC again to confirm the firewall findings under 1.2.1 and the firewall logging finding were cleared.

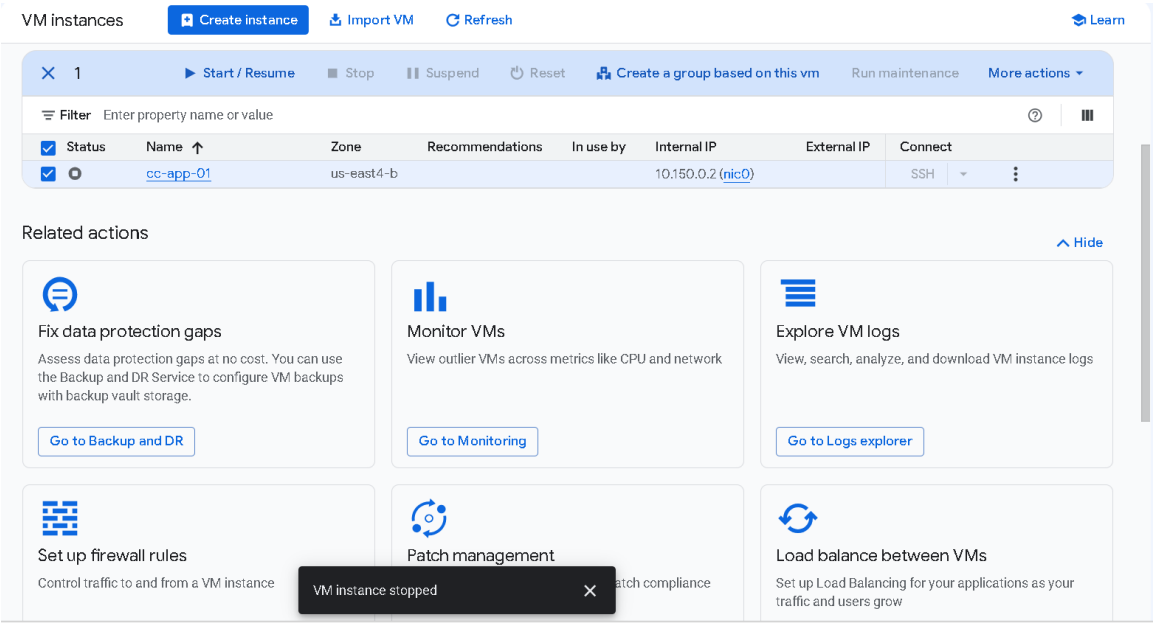


Figure 6. cc-app-01 stopped.

Recovery measures

1. We built a new VM, cc-app-02, in us-east4 from the trusted snapshot cc-app01-snapshot.
2. It is an e2-medium with a 10 GB balanced persistent disk.
3. We put it on the default subnet (10.150.0.0/20) with a private IP only and the external IP set to None, so it cannot be reached directly from the internet.
4. We turned on secure boot.
5. We gave it the cc network tag so limit-ports applies to it. HTTP, HTTPS and IP forwarding are all off.
6. We attached a dedicated service account instead of the default one with full API access.
7. We reviewed the security configuration of our VMs, storage buckets and network in SCC to find and fix any other misconfigurations.
8. We improved monitoring, including firewall rule logging and log review, so unauthorized access attempts are easier to spot.
9. We confirmed cc-app-02 was running and checked SCC again for anything left over.

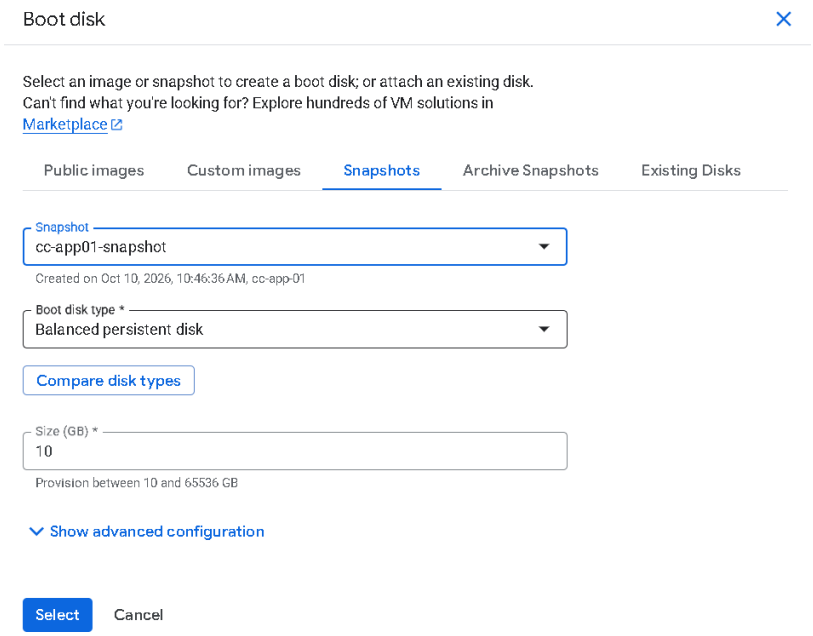


Figure 7. Boot disk: cc-app01-snapshot, 10 GB balanced persistent disk.

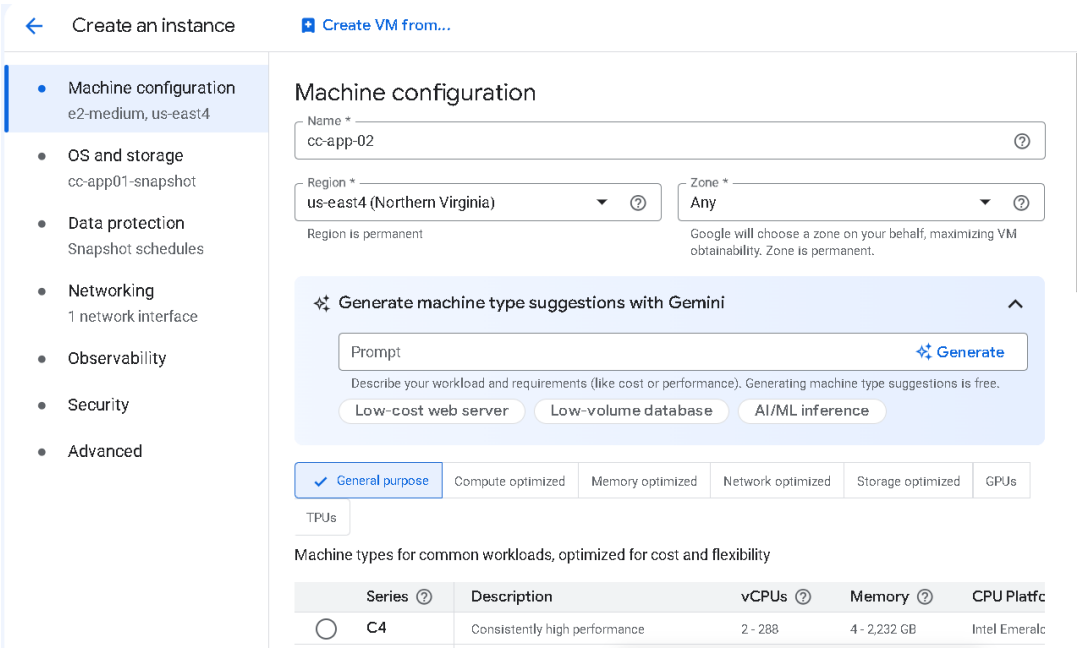


Figure 8. cc-app-02 machine configuration (e2-medium, us-east4).

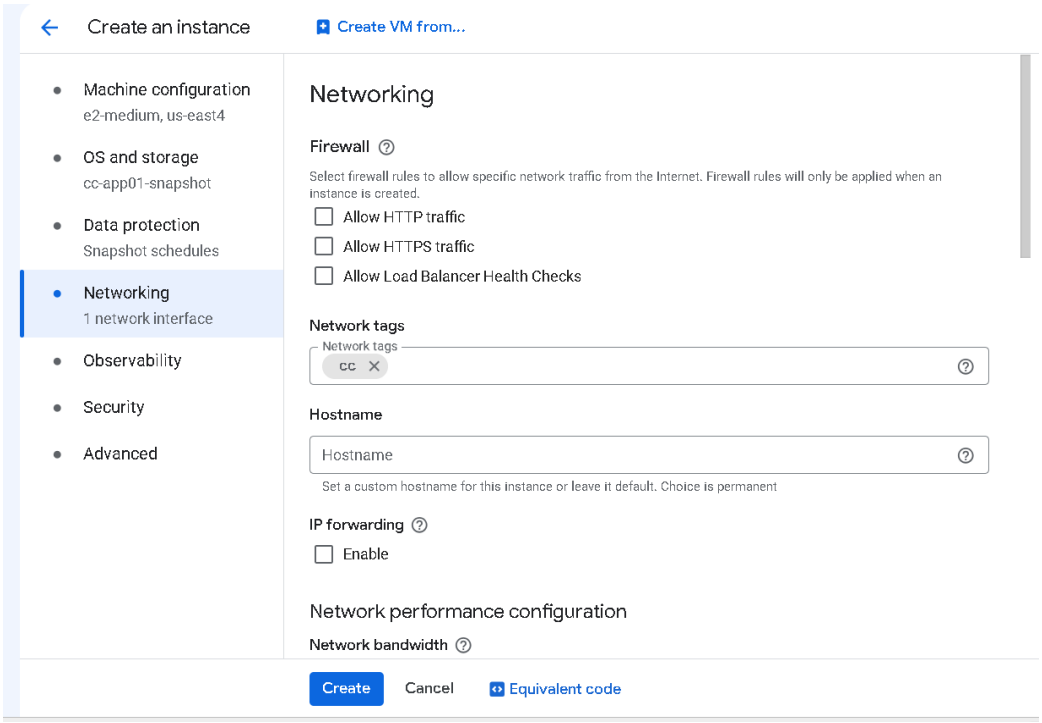


Figure 9. Networking: HTTP and HTTPS off, IP forwarding off, cc network tag.

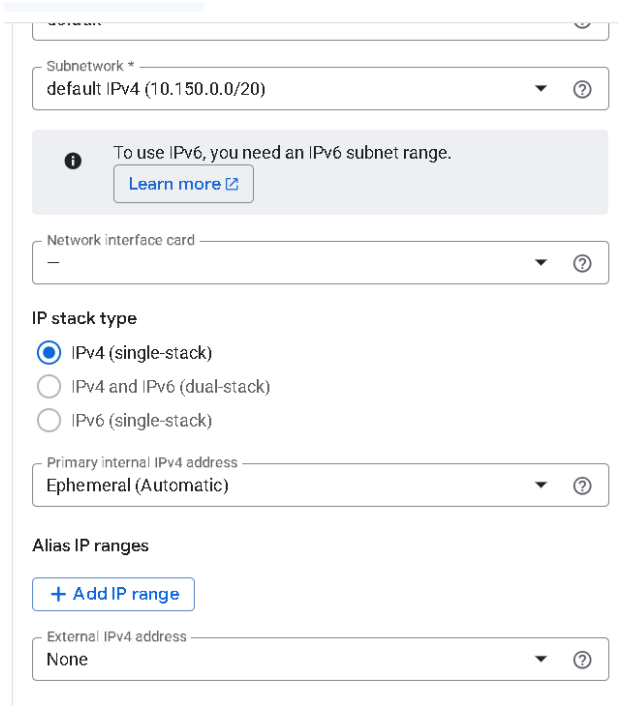


Figure 10. Default subnet, with the external IPv4 address set to None.

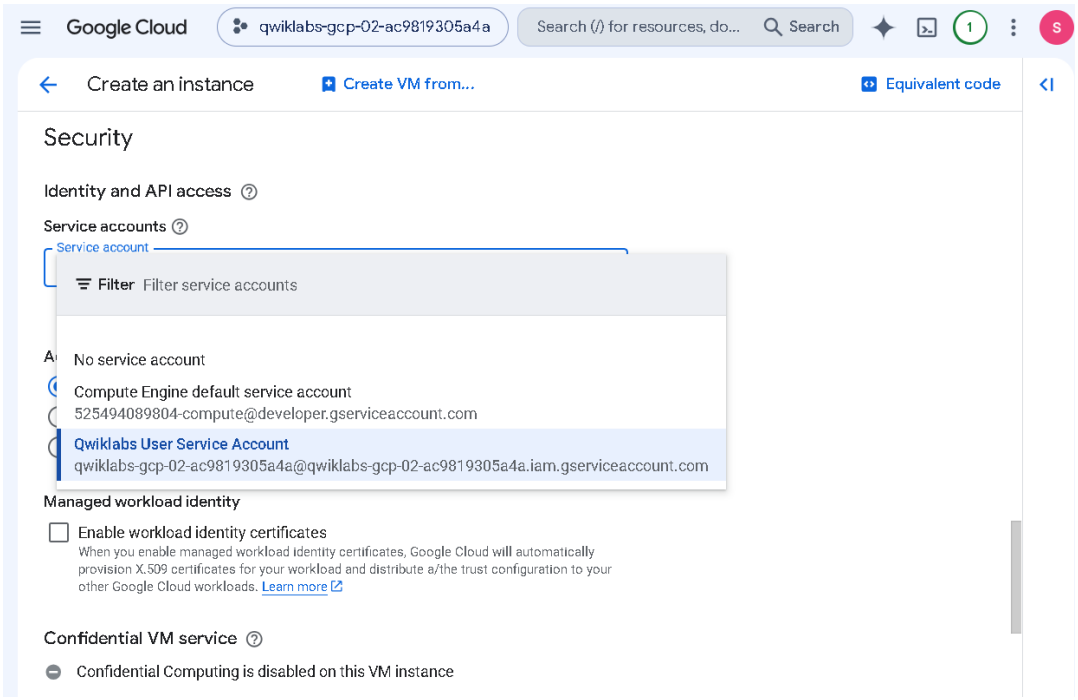


Figure 11. Service account selection.

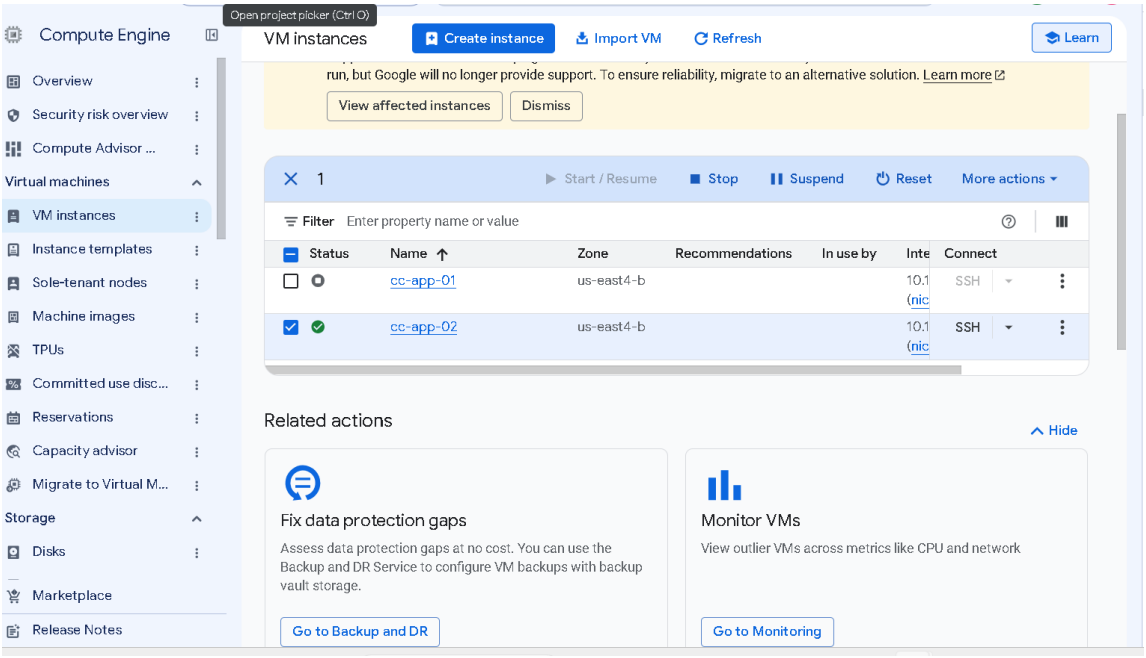


Figure 12. cc-app-02 running, cc-app-01 stopped.

Recommendations

1. Do not expose admin access to the internet. App VMs should not have public IP addresses, and SSH and RDP should never be open to every address. Going through Identity-Aware Proxy, like the new limit-ports rule does, is a good default. Strong passwords or SSH keys would also have stopped the brute-force attack. Multi-factor authentication on admin accounts would add another layer if a password is guessed. An organization policy can enforce all of this so one mistake does not bring it back.
2. Clean up service accounts. Workloads should not run as the default Compute Engine account with full API access. Each one should get its own account with only the roles it needs. We should also avoid user-managed keys and delete or rotate the ones that exist, because a single key on the VM was how the attacker got to BigQuery.
3. Protect the card data itself. It was sitting unencrypted in BigQuery, so anyone with access could read it. We should encrypt it, ideally with tokenization or customer-managed keys. We should also turn on public access prevention for buckets with an organization policy, so none can be made public again.
4. Have logging on from the start. VPC Flow Logs, firewall logging, bucket logging and Cloud Audit Logs should be part of our standard templates instead of something we turn on afterwards.

We should also set up alerts for a drop in PCI DSS compliance and for new high-severity SCC findings. The incident response run book should be updated with the steps we used here.

Remaining work

- Who and when: the attacker has not been identified, and forensics is still working out the exact times.
- Logging gaps: VPC Flow Logs (24 subnets), Cloud Audit Logging and bucket logging were not covered by the fixes above and still need to be closed.
- Smaller findings: SCC still lists medium and low findings on the project, network and subnets, which need a review.